Planejamento de Etapas

Etapa 4: Produção

Sócio Digital: Copiloto de Gestão Fiscal para Pequenos Negócios

Objetivo

Colocar o sistema no ar de forma segura, observável e reproduzível, com decisões claras de hospedagem, conformidade com a LGPD e rotina de atualização do acervo.

Ponto de partida

O Compose atual serve só ao ambiente local, com Ollama no host. O modelo de geração (Qwen3 8B) exige GPU para atender usuários reais. O CI faz lint e pytest. As normas mudam (por exemplo, a alíquota geral do ICMS-DF mudou em 2024), então o acervo precisa de atualização contínua.

Resultado esperado

Ambientes de teste e produção com deploy automatizado, segurança, monitoramento e plano de atualização e recuperação.

Resumo das issues

ID	Issue	Prioridade
E4.1	Decidir a hospedagem do LLM e do embedding (ADR com custo)	Alta
E4.2	Containerização completa e Compose de produção	Alta
E4.3	CI: build de imagens e testes de integração com Qdrant	Alta
E4.4	CD: deploy automatizado em staging e produção	Alta
E4.5	Segurança da API: limite de uso, segredos, CORS e cabeçalhos	Alta
E4.6	Conformidade com a LGPD	Alta
E4.7	Observabilidade: logs, métricas e alertas	Média
E4.8	Feedback do usuário por resposta	Média
E4.9	Pipeline de atualização do acervo	Média
E4.10	Backup e restauração de Qdrant e PostgreSQL	Média
E4.11	Teste de carga e dimensionamento	Média
E4.12	Modelagem de ameaças do sistema	Alta
E4.13	Plano de resposta a incidentes e de continuidade	Média

Cada issue abaixo está escrita para ser copiada ao GitHub: o título da seção vira o título da issue; os rótulos indicados devem ser criados no repositório; a descrição e os critérios de aceite vão no corpo. Não há responsável fixo: quem pegar a tarefa se atribui no GitHub. As prioridades são sugestões e devem ser confirmadas pela equipe.

Issues

[E4.1] Decidir a hospedagem do LLM e do embedding (ADR com custo)

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Alta

Rótulos: etapa-4, decisão, infra | **Depende de:** Nenhuma

Descrição

Comparar servidor próprio com GPU, serviço gerenciado e API de LLM de terceiros quanto a custo mensal, latência, privacidade dos dados da empresa e esforço. É a decisão que mais impacta a arquitetura, e deve ser tomada cedo.

Critérios de aceite

- Quadro comparativo com custo estimado e latência medida
- Decisão registrada e aprovada pela equipe
- Impacto na API e na concorrência listado

[E4.2] Containerização completa e Compose de produção

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Alta

Rótulos: etapa-4, infra, devops | **Depende de:** Decisão de hospedagem do LLM

Descrição

Imagens para API e frontend, serviços de Qdrant e PostgreSQL com volumes e backup, variáveis por ambiente e healthchecks. Remover a dependência de host.docker.internal para o modelo.

Critérios de aceite

- Todo o sistema sobe com um comando em ambiente limpo
- Configuração por variáveis, sem segredos no repositório
- Documentação de execução atualizada

[E4.3] CI: build de imagens e testes de integração com Qdrant

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Alta

Rótulos: etapa-4, ci, devops | **Depende de:** Containerização completa

Descrição

Ampliar o CI com build das imagens, execução de testes de integração com Qdrant e Postgres em serviço e cache de dependências.

Critérios de aceite

- Imagens construídas a cada PR
- Testes de integração rodando no CI
- Tempo total do CI monitorado

[E4.4] CD: deploy automatizado em staging e produção

Quem assume: a definir (atribuir no GitHub) **Prioridade:** Alta

Rótulos: etapa-4, cd, devops **Depende de:** CI de build de imagens

Descrição

Pipeline que publica imagens versionadas, implanta em staging a cada merge na main e em produção por aprovação, com forma de reverter.

Critérios de aceite

- Deploy em staging automático
- Produção com aprovação manual e reversão documentada
- Versão implantada visível na API

[E4.5] Segurança da API: limite de uso, segredos, CORS e cabeçalhos

Quem assume: a definir (atribuir no GitHub) **Prioridade:** Alta

Rótulos: etapa-4, segurança, backend **Depende de:** Autenticação

Descrição

Limitar requisições por usuário e por IP, gerenciar segredos fora do repositório, restringir CORS ao frontend, validar entradas e proteger contra abuso do endpoint de IA, que é caro de executar.

Critérios de aceite

- Limite de requisições com resposta 429
- Segredos em gerenciador, nunca no código
- Revisão de segurança (checklist) registrada

[E4.6] Conformidade com a LGPD

Quem assume: a definir (atribuir no GitHub) **Prioridade:** Alta

Rótulos: etapa-4, lgpd, segurança **Depende de:** Decisão de hospedagem do LLM

Descrição

CNPJ, faturamento e folha são dados da empresa e, em MEI, podem identificar uma pessoa. Definir base legal, política de privacidade, retenção, exclusão de conta e dados, e que dados chegam aos logs e a provedores externos de LLM.

Critérios de aceite

- Política de privacidade e termos redigidos
- Fluxo de exclusão de conta e dados implementado
- Logs sem dados sensíveis, verificado por teste
- Registro do que é enviado a serviços de terceiros

[E4.7] Observabilidade: logs, métricas e alertas

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Média

Rótulos: etapa-4, observabilidade, devops | **Depende de:** Containerização completa

Descrição

Logs estruturados com identificador de requisição; métricas de latência por etapa (busca, geração), taxa de abstenção, erros e uso de GPU; alertas para indisponibilidade de Qdrant ou do modelo.

Critérios de aceite

- Painel com latência, erros e abstenção
- Alertas de indisponibilidade configurados
- Identificador de requisição ligando logs e resposta

[E4.8] Feedback do usuário por resposta

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Média

Rótulos: etapa-4, produto, backend | **Depende de:** Tela do Assistente fiscal; LGPD

Descrição

Permitir marcar uma resposta como útil ou incorreta, com comentário opcional, ligada à pergunta, às fontes e à versão do acervo e do modelo, para alimentar a revisão de qualidade.

Critérios de aceite

- Feedback persistido sem dados pessoais desnecessários
- Relatório periódico de respostas marcadas como incorretas

[E4.9] Pipeline de atualização do acervo

Quem assume: a definir (atribuir no GitHub) | **Prioridade:** Média

Rótulos: etapa-4, dados, devops | **Depende de:** Medição de qualidade no CI

Descrição

Rotina periódica para recoletar fontes, detectar normas alteradas, reprocessar o refino, reindexar no Qdrant e reavaliar a qualidade antes de promover a nova coleção. Manter a coleção anterior para voltar atrás.

Critérios de aceite

- Execução agendada e reproduzível
- Alterações detectadas com relatório
- Promoção só após a medição de qualidade passar
- Reversão para a coleção anterior documentada

[E4.10] Backup e restauração de Qdrant e PostgreSQL

Quem assume: a definir (atribuir no GitHub)	**Prioridade:** Média
Rótulos: etapa-4, infra, confiabilidade	**Depende de:** Containerização completa

Descrição

Rotina de backup dos dados do usuário e da coleção, com teste de restauração. O README atual já alerta para não remover o volume do Qdrant.

Critérios de aceite

- Backups automáticos com retenção definida
- Restauração testada em ambiente separado

[E4.11] Teste de carga e dimensionamento

Quem assume: a definir (atribuir no GitHub)	**Prioridade:** Média
Rótulos: etapa-4, desempenho, qualidade	**Depende de:** Consultas simultâneas; hospedagem definida

Descrição

Simular usuários simultâneos no assistente para medir latência, taxa de erro e consumo, e definir o tamanho da infraestrutura e o número esperado de usuários no lançamento.

Critérios de aceite

- Cenários de carga versionados
- Limites medidos e registrados
- Meta de capacidade do lançamento definida

[E4.12] Modelagem de ameaças do sistema

Quem assume: a definir (atribuir no GitHub)	**Prioridade:** Alta
Rótulos: etapa-4, segurança, arquitetura	**Depende de:** Diagrama de arquitetura atualizado

Descrição

Mapear ativos (dados da empresa, acervo, chaves), pontos de entrada, fronteiras de confiança e ameaças (por exemplo, método STRIDE), com a mitigação e o responsável de cada risco. Cobre ainda a cadeia do acervo: um documento coletado alterado pode envenenar as respostas.

Critérios de aceite

- Documento de ameaças com severidade e mitigação por item
- Riscos altos viram issues com responsável
- Revisão antes do lançamento

[E4.13] Plano de resposta a incidentes e de continuidade

Quem assume: a definir (atribuir no GitHub)	**Prioridade:** Média
Rótulos: etapa-4, segurança, operação	**Depende de:** Modelagem de ameaças; backup e restauração

Descrição

Definir o que fazer se houver vazamento de dados, resposta fiscal errada com impacto, indisponibilidade do modelo ou acervo corrompido: quem decide, como comunicar usuários, como desligar o assistente de forma segura e como voltar à coleção anterior.

Critérios de aceite

- Procedimentos escritos por tipo de incidente
- Contatos e responsáveis definidos
- Simulação (exercício de mesa) realizada uma vez